

03 — Credential Dumping

Detection & forensics only — LSASS, SAM, DCSync artifacts

Educational / Defensive DFIR Study Notes

LEARNING OBJECTIVES

- Identify host and AD evidence that credential material was accessed
- Map Event IDs (4688, Sysmon 10, 4662, 4624) to investigative steps
- Treat credential-tool module strings as IOC hunt material — not operational guides
- Separate LSASS memory access evidence from DCSync directory replication evidence

SCOPE REMINDER

- This material covers detection, artifacts, and incident response only.
- Attacker actions are phrased as 'adversaries may...' then pivot to evidence.
- Tool/command names appear as IOC strings / exam knowledge — not how-to guides.

DEFENSIVE FRAMING

- Adversaries may attempt to access credentials in memory or via directory replication.
- This sheet documents how defenders DETECT and PROVE those activities.
- Command names appear only as IOC strings examiners expect you to recognize in logs.
- No dump recipes, exploit steps, or 'how to run' instructions are included.

What LSASS holds (conceptual)

The Local Security Authority Subsystem Service (`lsass.exe`) manages authentication material in memory. Adversaries may try to read that process memory to obtain NTLM hashes, Kerberos tickets/material, and sometimes cleartext passwords. Defenders prove **access attempts and dump artifacts**, then assume credential exposure and rotate.

SAM vs LSASS (exam distinction)

- **LSASS** — live authentication secrets in memory on a running system
- **SAM** — local account database on disk; decrypting it typically also needs the **SYSTEM** hive (boot key). Finding SAM+SYSTEM copied together is strong evidence of credential theft staging — hunt for unusual copies of those hives

IOC strings (exam knowledge only)

Security products and process-creation logs may show recognizable substrings associated with credential-dumping tooling. Treat these as **hunt strings**:

- `sekurlsa::logonpasswords` — classic Mimikatz LSASS-related module string seen in detections
- `lsadump::sam` / `lsadump::dcsync` — other module names taught as training IOCs
- Process names/paths containing `mimikatz`, or renamed binaries with those strings in memory
- Command lines referencing `procdump` targeting `lsass`, or `rundll32 + comsvcs + MiniDump` (known living-off-the-land dump pattern in detections)

Again: these are indicators you search for in 4688/Sysmon/EDR — not instructions.

How do I prove LSASS was accessed / dumped?

Evidence	What it shows	Notes
Sysmon Event 10 ProcessAccess	A process opened a handle to <code>lsass.exe</code> with concerning access rights	Primary modern detection; tune <code>GrantedAccess</code> ; exclude known AV
Security 4688 (cmdline audit)	Suspicious process command lines around dump utilities or IOC strings	Requires Audit Process Creation + Include command line
File: <code>lsass.dmp</code> / <code>*.dmp</code>	Memory dump artifact left on disk	Hash, timeline, and who created it (4688/USN)
Handle / EDR telemetry	Anomalous access to LSASS from unsigned or rare processes	Baseline rare parents: office → <code>lsass</code> is never normal
AV / ASR / Credential Guard logs	Blocked or allowed LSASS access attempts	Blocked ≠ never tried; still rotate if uncertain

Analyst workflow — suspected LSASS dump

- Pull Sysmon 10 where `TargetImage` ends in `lsass.exe`; stack by `SourceImage`
- Pull 4688/Sysmon 1 for those source processes; capture full command lines
- Search disk/MFT for `.dmp` near the event time; hash and isolate
- Assume credentials on that host (and any overlapping admin sessions) are burned → reset / revoke tickets
- Hunt lateral movement using those accounts after the dump timestamp

DCSync — directory replication abuse

Adversaries may abuse Active Directory replication rights to obtain credential data from a Domain Controller **without** interactively logging on to the DC like a normal user session. Detection is primarily via directory service auditing — not Sysmon 10 (Sysmon 10 is about process handle access such as LSASS, not DCSync).

Evidence	What to look for	Correlation
Security 4662	Object access with replication-related properties / GUIDs (DS-Replication-Get-Changes, Get-Changes-All, Filtered-Set)	AccessMask often Control Access (0x100) in public detection rules
Subject account	Unexpected user (not a DC machine account ending in \$; not known sync service)	Exclude legitimate AAD Connect / known replication principals carefully
Security 4624 Type 3	Same Logon ID as 4662 → Source Network Address	Alert if source IP is not a domain controller
Outcome signal	NTDS / domain hash material appearing on non-DC systems; sudden Golden Ticket-like auth anomalies later	Follow-on Kerberos anomalies; mass account usage

Prerequisites for 4662 visibility: Audit Directory Service Access must be enabled and an appropriate SACL configured (often on the domain root for extended rights). Without this, DCSync may leave little in standard Security logs — a common exam point.

Replication GUIDs (recognition)

- 1131f6aa-... — DS-Replication-Get-Changes
- 1131f6ad-... — DS-Replication-Get-Changes-All (high signal)
- 89e95b76-... — DS-Replication-Get-Changes-In-Filtered-Set
- Public detection rules often require AccessMask 0x100 (Control Access) plus one of these

Common exam traps

- Using Sysmon 10 as the answer for DCSync (wrong channel — use 4662 + 4624)
- Thinking SAM alone is enough (SYSTEM hive commonly needed — look for both)
- Equating 'tool blocked by AV' with 'credentials safe'
- Ignoring renamed tools — hunt behaviors and strings, not only filenames
- Forgetting credential rotation and ticket revocation after confirmed dump

Lab takeaways

FROM LAB 2-2 — CREDENTIAL DUMPING (DETECTION)

- 4688 cmdline: dump-tool patterns targeting lsass (ProcDump / comsvcs MiniDump strings as hunt patterns only).
- sekurlsa:... and similar = IOC hunt strings — no passwords/hashes from labs.
- No 4104 when dump used a native EXE is expected; pair Script Block with process-creation logging.
- DCSync: 4662 replication GUIDs + non-machine\$ subject + burst; correlate 4624 Type 3 for source IP ≠ DC.

QUICK REFERENCE

- LSASS proof: Sysmon 10 → lsass + 4688 cmdline + dump files
- IOC string example: sekurlsa::logonpasswords (hunt only)
- DCSync proof: 4662 replication GUIDs + unexpected account + 4624 source ≠ DC
- SAM staging: unusual SAM + SYSTEM hive copies
- Response: reset creds, revoke tickets, hunt lateral movement

Mini Self-Check

Answer these without looking back. Answers are on the next page.

- Q1.** Which Sysmon event is most associated with detecting LSASS handle access?
- Q2.** Name one Mimikatz-related string you might hunt in process command lines (IOC only).
- Q3.** Why correlate 4662 with 4624 in a DCSync investigation?
- Q4.** What pair of registry hives suggests local SAM credential staging when copied together?
- Q5.** Does a successful AV block of a dump tool mean no credential reset is needed? Why?

Self-Check Answers

- A1. Sysmon Event ID 10 (ProcessAccess) targeting lsass.exe.*
- A2. Example: sekurlsa::logonpasswords (or other lsadump::* module strings taught as IOCs).*
- A3. 4662 lacks reliable source IP; 4624 with the same Logon ID supplies the network origin to see if a non-DC initiated replication.*
- A4. SAM and SYSTEM.*
- A5. No — the attempt may have partially succeeded, used a different method, or occurred earlier. Treat exposure as likely until scoped; rotate and hunt.*